

1. Tạo User và Group

Nguyên tắc bảo mật cốt lõi là không phân quyền trực tiếp cho từng cá nhân mà phải cấp quyền thông qua nhóm (Group). Trong phạm vi triển khai của đề án (môi trường Workgroup), các tài khoản và nhóm sẽ được quản lý ở mức cục bộ.

Tạo Local Group: Khởi tạo các nhóm cục bộ tương ứng với cơ cấu tổ chức phòng ban (VD: G_IT, G_HR, G_Sales).

Tạo Local User: Khởi tạo tài khoản cục bộ cho từng nhân viên (VD: user_it, user_hr, user_sales) và thiết lập mật khẩu an toàn.

Gán User vào Group: Thêm các tài khoản vừa tạo vào đúng nhóm phòng ban tương ứng để dễ dàng quản lý quyền hạn.

Thư mục chia sẻ	Nhóm người dùng (Group)	Share Permissions	NTFS Permissions	Cấp quyền cụ thể
\Data_IT	G_IT (Phòng IT)	Everyone: Full Control	G_IT	Modify (Đọc, Ghi, Sửa, Xóa tệp)
	G_HR, G_Sales		G_HR, G_Sales	Deny (Hoặc không add vào list)
	Administrators		Administrators	Full Control
\Data_HR	G_HR (Phòng Nhân sự)	Everyone: Full Control	G_HR	Modify

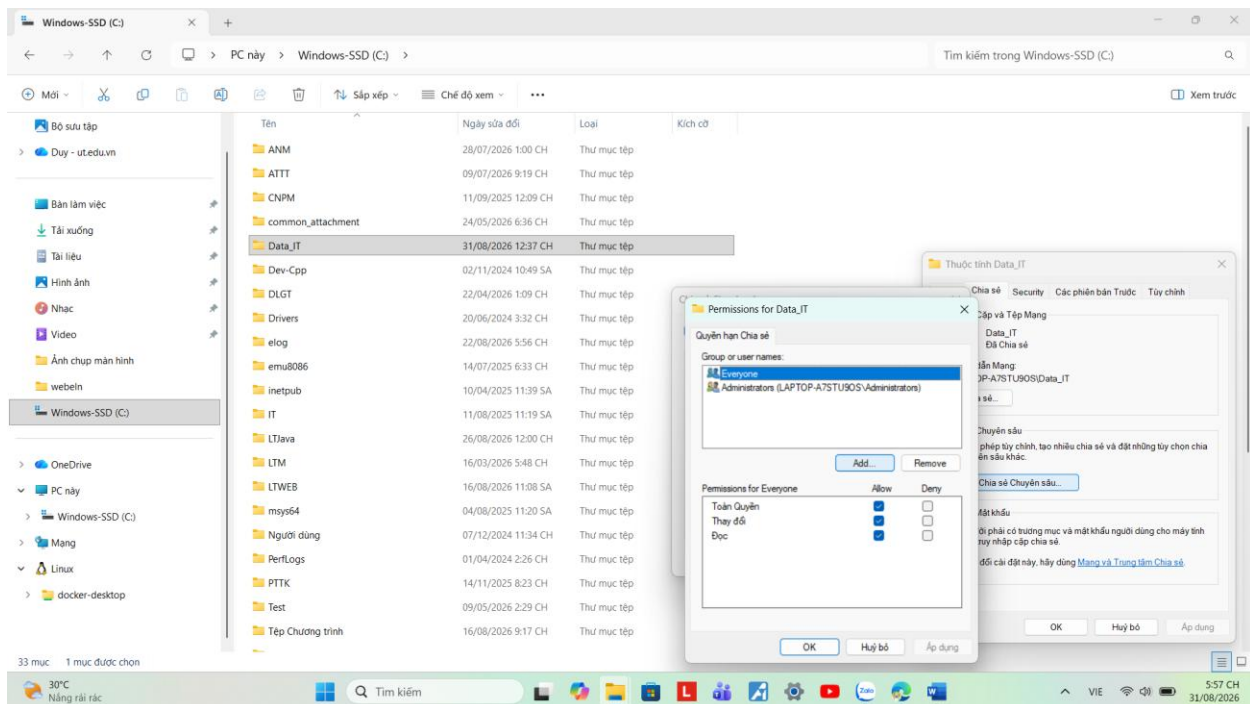
Thư mục chia sẻ	Nhóm người dùng (Group)	Share Permissions	NTFS Permissions	Cấp quyền cụ thể
\Data_Sales	G_IT, G_Sales		G_IT, G_Sales	Deny (Hoặc không add vào list)
	Administrators		Administrators	Full Control
	G_Sales (Phòng Kinh doanh)	Everyone: Full Control	G_Sales	Modify
	G_IT, G_HR		G_IT, G_HR	Deny (Hoặc không add vào list)
	Administrators		Administrators	Full Control
\Data_Public	Domain Users (Tất cả)	Everyone: Read	Domain Users	Read & Execute (Chỉ xem và chạy tệp)
	Administrators		Administrators	Full Control

2. Cấu hình Share Permissions

Đây là lớp phòng thủ mạng đầu tiên. Quyền Share và NTFS sẽ kết hợp với nhau theo nguyên tắc "quyền nào khắt khe hơn sẽ được áp dụng".

Chia sẻ thư mục: Nhấp chuột phải vào thư mục dữ liệu tổng (VD: FileServer_Data), chọn Properties > Sharing > Advanced Sharing.

Thiết lập quyền: Xóa nhóm Everyone mặc định để tránh rủi ro. Thêm nhóm Authenticated Users (những tài khoản đã đăng nhập thành công) và cấp quyền Change và Read.



Access-based Enumeration (ABE): Khuyến nghị bật tính năng này trong Server Manager > File and Storage Services để tự động ẩn các thư mục mà người dùng không có quyền truy cập.

1. Tạo các Groups cục bộ (Local Groups) cho phòng ban

New-LocalGroup -Name "G_IT" -Description "Nhom IT"

New-LocalGroup -Name "G_HR" -Description "Nhom Nhan Su"

New-LocalGroup -Name "G_Sales" -Description "Nhom Kinh Doanh"

2. Tạo Users cục bộ

```
$Password = ConvertTo-SecureString "P@ssw0rd123" -AsPlainText -Force
```

```
New-LocalUser -Name "user_it" -FullName "IT User" -Password $Password -  
PasswordNeverExpires
```

```
New-LocalUser -Name "user_hr" -FullName "HR User" -Password $Password -  
PasswordNeverExpires
```

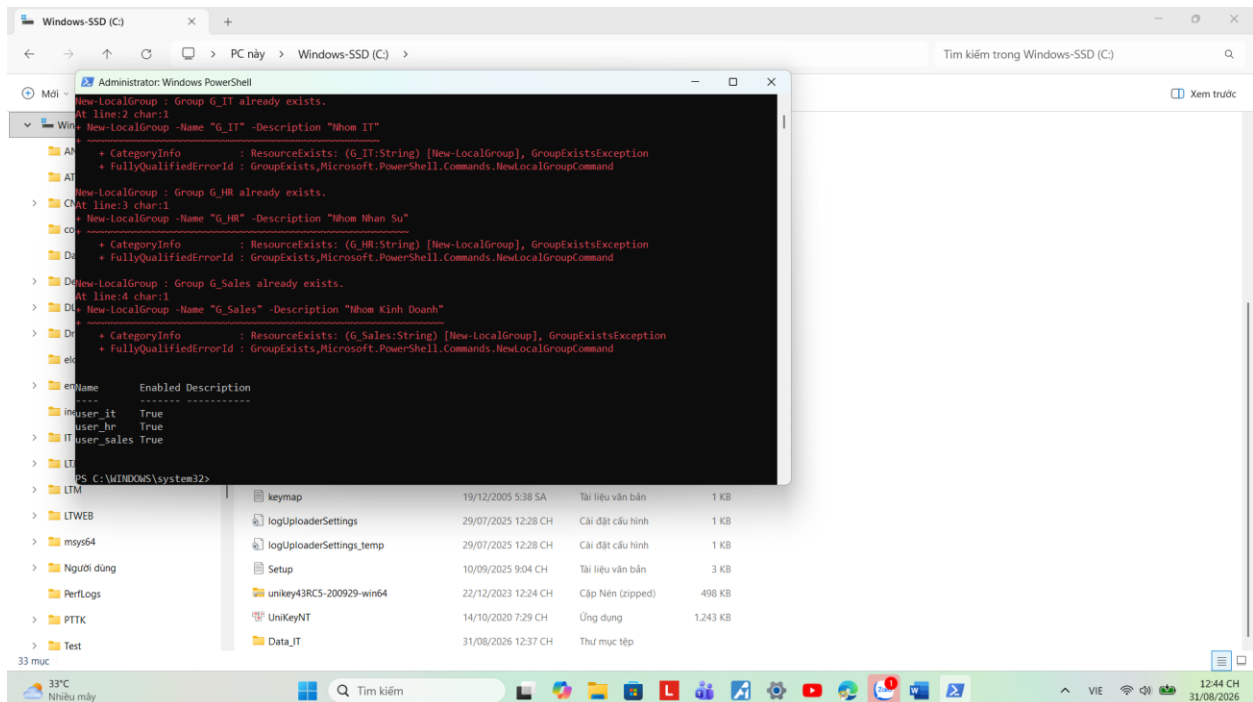
```
New-LocalUser -Name "user_sales" -FullName "Sales User" -Password  
$Password -PasswordNeverExpires
```

3. Thêm Users vào đúng Group cục bộ của họ

```
Add-LocalGroupMember -Group "G_IT" -Member "user_it"
```

```
Add-LocalGroupMember -Group "G_HR" -Member "user_hr"
```

```
Add-LocalGroupMember -Group "G_Sales" -Member "user_sales"
```



3. Cấu hình NTFS Permissions

Đây là lớp bảo mật chi tiết và quan trọng nhất, quyết định quyền hạn thực tế trên từng thư mục con.

Ngắt kế thừa (Disable Inheritance): Tại tab Security của các thư mục con (VD: Folder_HR, Folder_IT), truy cập Advanced > Disable inheritance để xóa các quyền mặc định áp từ thư mục cha xuống.

Phân bổ quyền:

Thư mục riêng của phòng ban: Cấp quyền Modify cho Group của phòng đó (để họ được đọc, tạo, sửa, xóa file của mình).

Ban Giám đốc (G_Directors): Cấp quyền Modify (hoặc Full Control) trên mọi thư mục.

Thư mục Public chung: Cấp quyền Read & Execute cho mọi nhân viên (chỉ được xem và copy, không được sửa hay xóa).

